Applied Security Lab Write-Up

Dormant Account With Standing Access — Stale External Contractor

Lab title	Dormant Account With Standing Access
Author	Kevin Mwangi
Environment	Microsoft 365 E5 trial tenant: wafulamwangi.onmicrosoft.com (isolated lab tenant, no production data)
Date	October 2026
Target platform	Microsoft Entra ID / SharePoint Online
Classification	Internal lab exercise

1. Executive Summary

This lab examines a quiet but common identity risk: an account that has never authenticated, yet retains real, standing, writable access to tenant resources. A test account representing an offboarded or long-idle external contractor showed zero sign-in activity across the full available log retention window while still holding active membership in a publicly discoverable Microsoft 365 group with a linked SharePoint document library. Signing into the dormant account directly confirmed it could view, open, and modify documents in that library without any additional prompt, review, or friction.

Unlike the earlier labs in this series, this finding involves no exploit technique at all. It demonstrates that Microsoft 365 does not, by default, surface or flag dormant accounts with standing access. The risk persists through inaction alone: nobody needs to misconfigure anything further for this gap to remain open indefinitely.

2. Scenario

Contractor and vendor accounts are routinely created for the duration of an engagement and then left in place long after the engagement ends. Often because offboarding is a manual, easily forgotten step rather than an automated or audited one. An attacker who obtains a credential for such an account (through a historical breach, password reuse, or simple guessing against a weak or default password) inherits whatever access that account was ever granted, with no activity baseline to flag the first login as anomalous, because the account has no prior activity to compare against in the first place.

This lab models that exact scenario using the 'External Contractor' test account, created in Week 1 and never subsequently signed into until deliberately tested below.

3. Evidence

3.1 Confirming the account has never authenticated

Entra ID Sign-in Logs were queried for the External Contractor account across the widest available retention window (last 1 month). No sign-in events of any kind were returned, confirming the account has been fully dormant since creation.

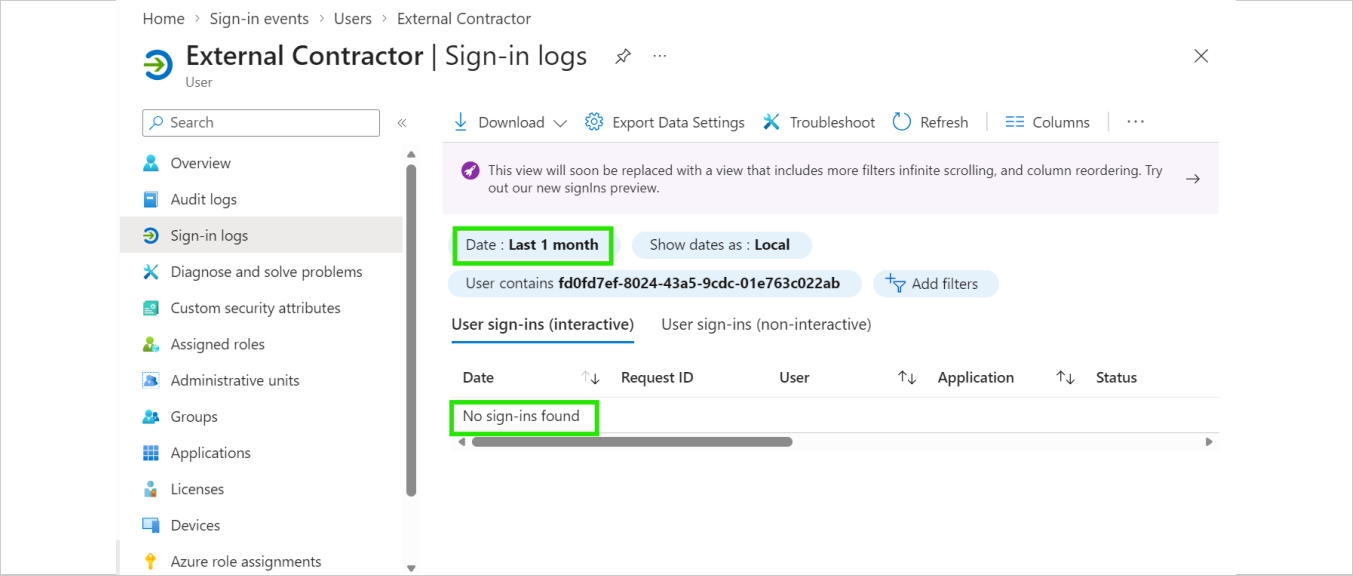


Figure 1 — Sign-in logs, last 1 month: "No sign-ins found" for External Contractor

3.2 Confirming standing group membership

Despite zero authentication activity, the account's Groups blade confirms active membership in two groups: 'External-Contractors' (a Microsoft 365-type group created specifically for this test) and the tenant's default all-members group ('USIU-A'). Membership in both groups is current and was never time-boxed or set to expire.

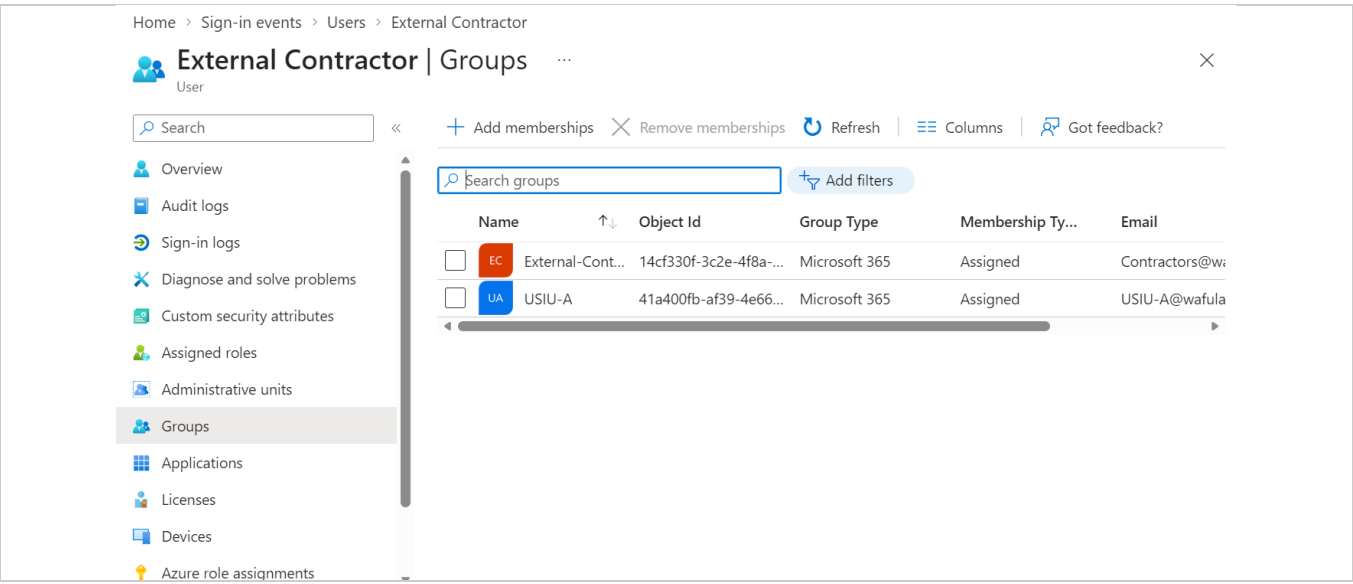


Figure 2 — External Contractor's active group memberships despite no sign-in history

Notably, the External-Contractors group itself is configured as a Public group, meaning its membership and, depending on tenant settings, its content are discoverable by any user in the tenant without an approval step. This compounds the core finding: not only does the dormant account retain access, but the group granting that access is itself broadly discoverable.

3.3 Resource access via the group's SharePoint site

Every Microsoft 365 group auto-provisions a linked SharePoint site and document library. A representative file ('Vendor invoice template.xlsx') was added to the External-Contractors group's Documents library to simulate real business content a contractor engagement might reasonably produce or require access to.

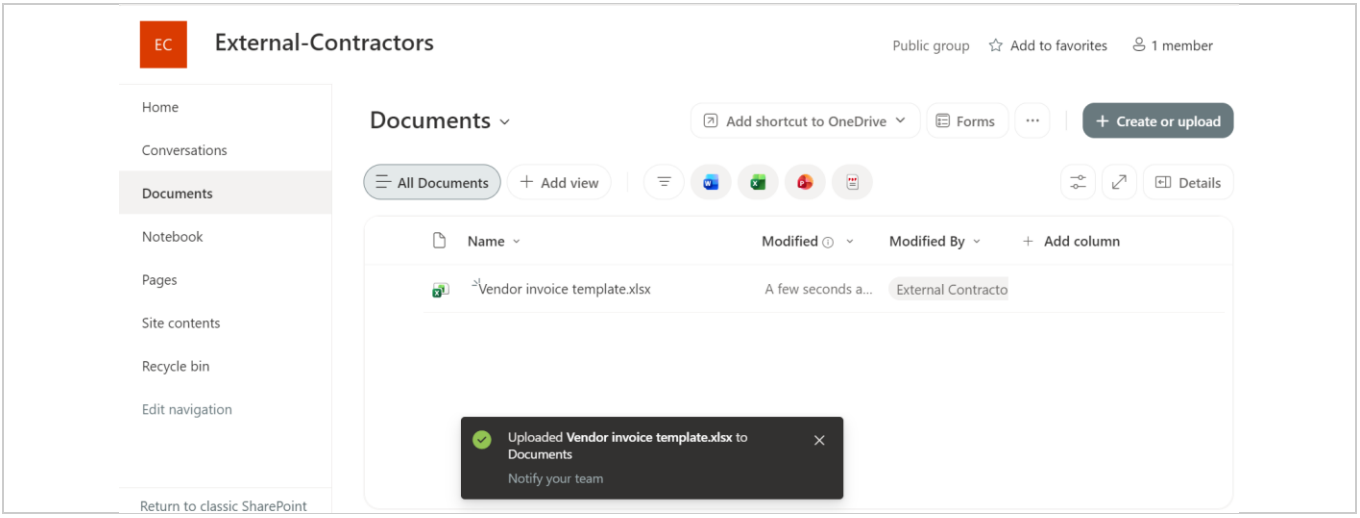


Figure 3 — Document uploaded to the External-Contractors group's SharePoint library

3.4 Verifying access from the dormant account itself

Signing in directly as the External Contractor account (completing a forced first-time password change, confirming this was genuinely the account's first authentication) confirmed full access to the document library, not merely read access, but the full action set including Open, Share, Copy link, Delete, and Pin to top.

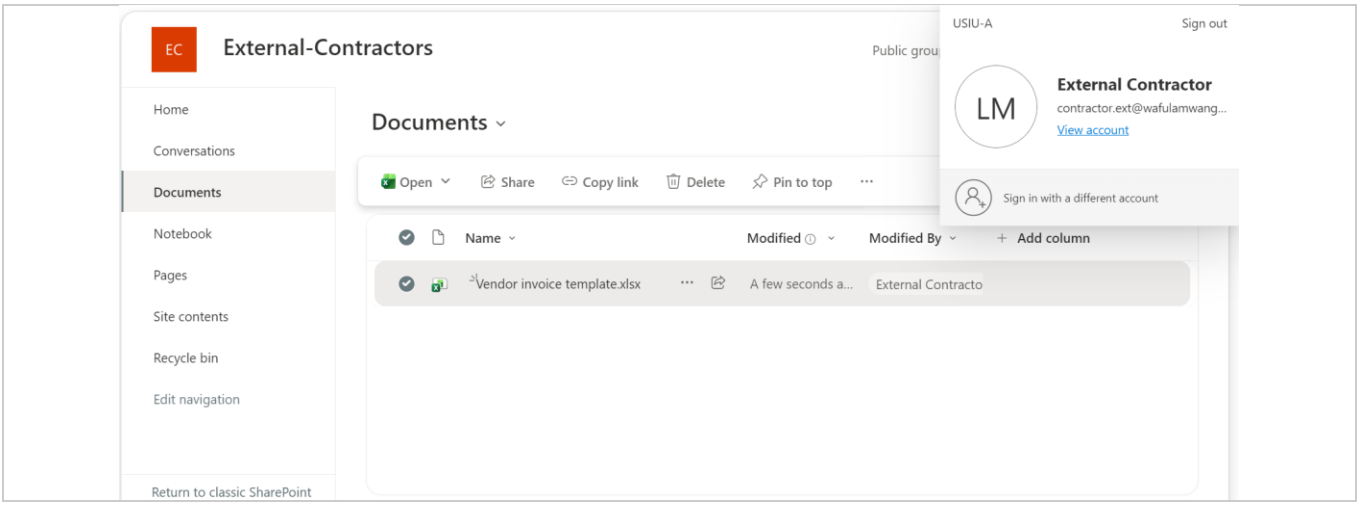


Figure 4 — Signed in as External Contractor: full read/write/delete access to the library, confirmed live

4. Impact

A credential for this account, however it is obtained, grants immediate, unreviewed access to real business content, with no behavioral anomaly to trigger detection, because the account has no prior activity baseline against which a first login could appear unusual. In a production tenant, this pattern frequently extends across many offboarded contractor, vendor, and former-employee accounts simultaneously, each representing a standing, silent point of entry that ordinary security monitoring — which typically looks for anomalies relative to a user's established behavior.

5. Detection

- Entra ID Sign-in Logs: a scheduled query for accounts with zero sign-in activity over a defined threshold (e.g., 90 days) combined with active group membership or license assignment flags exactly this pattern
- Entra ID Identity Governance → Access Reviews: configure a recurring review specifically for guest, contractor, or vendor-tagged accounts, rather than relying on ad-hoc offboarding

- Microsoft Entra ID usage reports / Microsoft Graph reports API (getInactiveUsers-style queries where available) to surface accounts that exist but have never completed a sign-in
- Audit group visibility settings: flag and review any Public Microsoft 365 group with linked SharePoint or Teams resources holding sensitive or business-critical content
- SharePoint Online sharing reports: periodically review who has accessed, or who is capable of accessing, document libraries tied to contractor/vendor-facing groups

6. Remediation Recommendations

- Implement a formal offboarding process tied to contract/engagement end dates, with automatic account disablement rather than manual, easily-forgotten deactivation
- Set Microsoft 365 groups intended for external or contractor use to Private rather than Public by default, and review this setting as a standing policy
- Apply Entra ID Access Reviews on a recurring cadence (e.g., quarterly) specifically scoped to external/contractor-tagged accounts and the groups they belong to
- Consider time-boxed group membership (expiration policies) for contractor accounts tied to a known engagement duration, rather than indefinite membership
- Require a minimum authentication event (e.g., an enforced first sign-in within N days of account creation) before granting standing group-based resource access, so dormant-but-provisioned accounts are flagged rather than silently trusted

7. Appendix — Evidence Index

- Figure 1 — Sign-in logs: no activity across full retention window
- Figure 2 — Active group memberships despite dormancy
- Figure 3 — Document uploaded to the linked SharePoint library
- Figure 4 — Live verification: dormant account signed in with full document access